

# CIS Critical Security Controls v8.1 — Compliance Report

Cisco Secure Workload | IG2-Lead Mapping with IG1/IG3 Deltas

Cisco Secure Workload — Compliance Mapping Series

Version 1.0 (draft — pending SME review)

## Table of Contents

## Cisco Secure Workload — CIS Controls v8.1 Compliance Mapping

### How to read this report

This report describes how Cisco Secure Workload (CSW) supports an organisation's posture against the **CIS Critical Security Controls v8.1** at the workload tier. Default depth is written for **Implementation Group 2 (IG2)**, with IG1 and IG3 deltas called out where the work materially changes.

**Why CIS Controls and not just NIST 800-53.** The CIS Controls are an operationally ordered, prioritised subset of what NIST 800-53 describes. Where 800-53 lists 1,000+ controls, CIS compresses to **18 Controls** and **~153 Safeguards**, ranked by what defends against actual attacks first. Many programmes use CIS as the “what to do this year” view and 800-53 as the “what to satisfy in the contract” view.

**Companion document.** The accompanying *CIS Controls v8.1 Reference Design* walks through deployment, scope labelling per IG, and the per-Safeguard implementation steps. Read this report for the audit-narrative view; read the reference design for the deployment view.

---

### How to read the Coverage column

**Direct** means Secure Workload produces the primary evidence artifact for that row — segmentation, policy, flow and process telemetry, inventory, vulnerability and reachability, or forensic reconstruction. Direct is still evidence, not an attestation.

**Supporting** means Secure Workload contributes an input that feeds or complements another control, tool, or process — detection input only, reconciled against an external register, or one log source among several.

**Evidence Required** means Secure Workload has no record for that row. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

Every report in this set now uses the same three coverage words — Direct, Supporting, and Evidence Required. Coverage describes what evidence Secure Workload produces; it never means the control is passed.

## 1. Executive Summary

CIS Controls v8.1 organises 18 Controls and ~153 Safeguards by Implementation Group (IG1 / IG2 / IG3). CSW directly addresses six of the 18 Controls and supports another seven; the remaining five are explicitly outside CSW's scope (training, email/web, backup, and similar non-workload functions).

### What CSW changes for a CIS Controls programme:

- **Control 1 / 2 — Inventory.** Continuous, agent-based workload inventory and per-workload software inventory, refreshed at the cadence the IG band expects (monthly for IG1, weekly for IG2, continuous for IG3). Cloud connectors capture ephemeral assets even without an agent.
- **Control 4 — Secure Configuration.** Daily configuration baseline per workload (OS, packages, listening ports, processes) with drift detection and change-ticket attribution.
- **Control 7 — Continuous Vulnerability Management.** Per-workload CVE inventory with CVSS, EPSS, and exploit-availability context, prioritised by reachability in the actual conversation graph (not just CVSS score).
- **Control 8 — Audit Log Management.** Per-flow + per-process audit detail forwarded to your SIEM, retained per the 90-day IG2 minimum (or longer per overlapping framework requirements).
- **Control 13 — Network Monitoring and Defense.** The densest CSW fit. East-west visibility, segmentation enforcement, behavioural detection, conversation-graph anomalies, and SIEM forwarding — the substrate for Safeguards 13.1 through 13.10.
- **Control 17 — Incident Response.** Six-artefact reconstruction bundle for every declared incident, ready to feed playbooks and post-incident review (Safeguard 17.8).

**What CSW does not change.** CSW does not address Controls 5 (Account Management), 9 (Email & Web Browser), 11 (Data Recovery), 14 (Security Awareness), or the HR/physical sub-Safeguards inside other Controls. Reference your identity, email/web, backup, and training stacks for those.

---

## 2. Compliance Posture Summary

| Control | Title                                      | Coverage | CSW contribution (IG2 default)                                             |
|---------|--------------------------------------------|----------|----------------------------------------------------------------------------|
| 1       | Inventory and Control of Enterprise Assets | Direct   | Continuous workload + cloud asset inventory; quarantine policy for net-new |
| 2       | Inventory and                              | Direct   | Per-workload                                                               |

| Control | Title                                                  | Coverage          | CSW contribution (IG2 default)                               |
|---------|--------------------------------------------------------|-------------------|--------------------------------------------------------------|
|         | Control of Software Assets                             |                   | package inventory; allow-list deviation alerting             |
| 3       | Data Protection                                        | Supporting        | Egress observation (DLP remains primary)                     |
| 4       | Secure Configuration of Enterprise Assets and Software | Direct            | Daily baseline + drift report tied to change ticket          |
| 5       | Account Management                                     | Evidence Required | Identity / PAM tooling                                       |
| 6       | Access Control Management                              | Supporting        | Workload-side enforcement; identity is upstream              |
| 7       | Continuous Vulnerability Management                    | Direct            | Continuous CVE inventory + reachability-aware prioritisation |
| 8       | Audit Log Management                                   | Direct            | Per-flow + per-process telemetry to SIEM                     |
| 9       | Email and Web Browser Protections                      | Evidence Required | Email / web stack                                            |
| 10      | Malware Defenses                                       | Supporting        | Behavioural rules layered with endpoint AV                   |
| 11      | Data Recovery                                          | Evidence Required | Backup product                                               |
| 12      | Network Infrastructure Management                      | Supporting        | Workload-side complement to network team config              |
| 13      | Network Monitoring and Defense                         | Direct            | East-west visibility, segmentation, behavioural detection    |
| 14      | Security Awareness and Skills Training                 | Evidence Required | HR / training                                                |
| 15      | Service Provider Management                            | Supporting        | Vendor-egress observation (contractual is upstream)          |
| 16      | Application Software                                   | Supporting        | CVE inventory feeds                                          |

| Control | Title                        | Coverage          | CSW contribution (IG2 default)                  |
|---------|------------------------------|-------------------|-------------------------------------------------|
|         | Security                     |                   | the SDLC                                        |
| 17      | Incident Response Management | Direct (evidence) | Six-artefact reconstruction bundle              |
| 18      | Penetration Testing          | Supporting        | Pre/post reachability + activity reconstruction |

**Posture takeaway.** Direct on six Controls (1, 2, 4, 7, 8, 13); supporting on seven; out of scope on five. This is consistent with CSW’s positioning as a workload-protection platform: it does the workload-tier jobs well and explicitly defers identity, email/web, backup, and training to the appropriate owners.

### 3. Mapping Table — CIS Safeguard → CSW Capability → Evidence Artefact

| Safeguard | Topic (abbreviated)               | CSW capability                                       | Evidence artefact (audit-ready)                    |
|-----------|-----------------------------------|------------------------------------------------------|----------------------------------------------------|
| 1.1       | Inventory of enterprise assets    | Continuous workload inventory + cloud asset metadata | Inventory CSV per scope, dated to IG cadence       |
| 1.2       | Address unauthorised assets       | Quarantine policy applied to net-new workloads       | Quarantine log with disposition                    |
| 1.3, 1.5  | Active + passive discovery        | Sensor coverage + cloud orchestrator polling         | Sensor coverage report + cloud connector status    |
| 2.1       | Software inventory                | Per-workload package + version inventory             | Per-workload package inventory dated to IG cadence |
| 2.2       | Authorised software supported     | Cross-reference vs. vendor-support list              | Unsupported-software register                      |
| 2.3       | Address unauthorised software     | Alert + (IG3) behavioural-policy block               | Unauthorised-software alert log with disposition   |
| 2.5–2.6   | Allow-listed software / libraries | Allow-list catalogue + behavioural enforcement       | Allow-list export + deviation log                  |
| 4.1       | Secure configuration process      | Daily baseline + drift report                        | Baseline export + daily diff log with              |

| Safeguard  | Topic (abbreviated)                 | CSW capability                                         | Evidence artefact (audit-ready)                            |
|------------|-------------------------------------|--------------------------------------------------------|------------------------------------------------------------|
|            |                                     |                                                        | change-ticket attribution                                  |
| 4.4        | Default deny on FW                  | CSW segmentation enforcement at workload               | Workspace export per scope                                 |
| 4.6        | Secure software config              | Per-workload listening-port + service inventory        | Listening-port inventory dated to IG cadence               |
| 6.1–6.5    | Access control management           | Workload-side identity-aware enforcement               | Policy export with rule provenance per scope               |
| 7.1–7.5    | Continuous vulnerability management | Continuous CVE inventory + reachability prioritisation | CVE list per workload dated to IG cadence                  |
| 7.7        | Remediate detected vulnerabilities  | Patch SLA tracking + compensating-control register     | Patch SLA compliance trend + compensating-control register |
| 8.2        | Collect audit logs                  | SIEM forwarding configuration                          | SIEM config screenshot + sample event                      |
| 8.5        | Detailed audit logs                 | Per-flow + per-process detail                          | Sample log entries with flow + process attribution         |
| 8.7, 8.10  | Retain audit logs                   | SIEM retention + CSW window                            | Retention policy + retrieval evidence over the window      |
| 8.11       | Audit log reviews                   | Quarterly review of CSW alert summary                  | Review minutes per cadence                                 |
| 10.x       | Malware defenses                    | Behavioural rules layered with endpoint AV             | Detection rule catalogue + sample alert                    |
| 12.2       | Secure protocols                    | Plaintext-flow detection + DENY enforcement            | Plaintext-flow alert log + segmentation policy             |
| 12.4       | Architecture diagrams               | ADM dependency export                                  | ADM graph export per scope                                 |
| 13.1, 13.6 | Centralised monitoring + flow       | CSW flow telemetry + SIEM forwarding                   | Flow log retention configuration +                         |

| Safeguard  | Topic (abbreviated)                               | CSW capability                                      | Evidence artefact (audit-ready)                                 |
|------------|---------------------------------------------------|-----------------------------------------------------|-----------------------------------------------------------------|
|            | logs                                              |                                                     | sample retrieval                                                |
| 13.2, 13.3 | Host + network IDS                                | Behavioural rules + anomaly detection               | Detection rule catalogue + anomaly alert log                    |
| 13.4       | Traffic filtering between segments                | CSW segmentation policy enforcement                 | Workspace export with simulation → enforcement log              |
| 13.5       | Remote-asset access control                       | Bastion-source-restricted mgmt protocol allow rules | Allow rule policy export + bastion source-set documentation     |
| 13.7–13.10 | HIPS, NIPS, port-level, app-layer filtering (IG3) | Behavioural rules + segmentation enforcement        | Policy export + behavioural rule catalogue                      |
| 15.1, 15.4 | Service provider management (technical lens)      | Vendor-egress observation + reconciliation          | Vendor-egress report + reconciliation against contract register |
| 16.1, 16.6 | Application security process                      | CVE inventory feeds SDLC + reachability for triage  | CVE feed integration + triage workflow evidence                 |
| 17.1–17.8  | Incident response management                      | Six-artefact incident dossier                       | Sample dossier per quarter + MTTR trend                         |
| 18.1–18.5  | Penetration testing                               | Pre/post reachability + activity reconstruction     | Pre/post reachability reports + red-team activity export        |

## 4. Out-of-Scope and Complementary Controls

CSW does **not** address the following Controls; reference the noted complementary controls.

| Control                                       | Owner               | Complementary control                      |
|-----------------------------------------------|---------------------|--------------------------------------------|
| Control 5 — Account Management                | Identity / PAM team | AD/LDAP, PAM (CyberArk, BeyondTrust), MFA  |
| Control 9 — Email and Web Browser Protections | Email / web team    | Email security gateway, secure web gateway |
| Control 11 — Data Recovery                    | Backup / DR team    | Backup product + restore testing           |

| Control                                             | Owner                        | Complementary control                                     |
|-----------------------------------------------------|------------------------------|-----------------------------------------------------------|
| Control 14 — Security Awareness and Skills Training | HR / Security training       | LMS + phishing simulation programme                       |
| Sub-Safeguards: Physical access, HR, Crypto modules | Facilities / HR / Crypto SME | Physical security, HR process, FIPS 140-validated modules |

CSW's role in a complete CIS Controls programme is the workload- tier visibility, segmentation, and continuous evidence engine. It explicitly defers identity, email/web, backup, and training to the appropriate owners.

---

## 5. Suggested Next Steps

For organisations adopting or maturing CIS Controls posture with CSW:

1. **Confirm your IG target.** IG1 / IG2 / IG3 calibration drives inventory cadence, scan cadence, log retention, and segmentation depth. Get this signed off by security leadership before scoping.
  2. **Pilot on Controls 1, 2, 7, 13.** These are the densest CSW alignment and produce the fastest visible wins. Inventory and software inventory are the foundation; Controls 7 and 13 are where the daily security work lives.
  3. **Tie drift detection to your change-management ticketing day one.** Orphan changes (Safeguard 4.1) are one of the most asked-for evidence types in CIS assessment, and CSW produces the feed automatically.
  4. **Pair Control 13 with the SIEM you already have.** CSW does not replace the SIEM; it feeds richer, workload-tier data. The uplift to Safeguards 13.1 / 13.3 / 13.6 comes from forwarding CSW telemetry to the SIEM you already operate.
  5. **Build the Control 17 incident dossier template once.** The six-artefact bundle is reusable across every incident; standardise the format so SOC analysts produce identical artefacts under pressure.
  6. **Plan SME review.** This document is a v1 mapping. Before being relied upon in a formal compliance engagement, route to a CIS Controls assessment specialist for currency and to a current Cisco Secure Workload SE for product-capability accuracy.
- 

## 6. Disclaimer

This report and its companion reference design describe how Cisco Secure Workload capabilities can support a CIS Critical Security Controls v8.1 programme at the workload tier. They are **not** legal or compliance advice and do not constitute a finding of compliance.

Specifically:

- CIS publishes the authoritative Safeguard text and Implementation Group mapping at <https://www.cisecurity.org/>. Always validate against the **current effective version** of the Controls (v8.1 at the time of authoring; subsequent versions and minor revisions occur).
- Mapping a Safeguard to a CSW capability does not by itself satisfy the Safeguard. Safeguards expect documented process, evidence cadence, and management review — CSW supplies the technical layer that those process requirements depend on.
- CSW does not address Controls 5, 9, 11, 14 or the HR/physical sub-Safeguards within other Controls. Reference your identity, email/web, backup, and training stacks for those.

This document should receive subject-matter-expert review for both CIS Controls accuracy and current Cisco product capability before being used in a customer engagement.